

THÔNG TIN CHUNG

- **Topic Code & Name:** T09 - Security Testing (DAST / SAST)
- **Nhóm:** Group 06

1. DANH SÁCH CÔNG CỤ ĐỀ XUẤT

- **Công cụ SAST:** Semgrep (Quét tĩnh mã nguồn tốc độ cao dựa trên ruleset OWASP Top-10).
- **Công cụ AI-Augmented:** Google Gemini API (Đóng vai trò Triage - tự động lọc lỗi giả, giải thích lỗi hổng và gợi ý bản vá).
- **Công cụ DAST (Mã nguồn mở):** OWASP ZAP (Quét động tự động trên các endpoint đang vận hành của EShop để xác thực lỗi).
- **Công cụ DAST (Thương mại):** Burp Suite (Công cụ kiểm thử bảo mật Web tiêu chuẩn của ngành Pentest, chuyên dùng can thiệp thủ công và rà quét nâng cao).

2. MA TRẬN SO SÁNH

Tiêu chí	Semgrep (SAST)	OWASP ZAP (DAST)	Burp Suite (DAST/Pentest)	Google Gemini API (AI)
Licence cost	Miễn phí (Bản Community).	Miễn phí hoàn toàn (Mã nguồn mở).	Miễn phí bản Community. Bản Pro \$449/năm.	Miễn phí hoàn toàn (Sử dụng Free Tier của Google AI Studio dành cho Developer).
Learning curve	Thấp - Trung bình (Dễ cài đặt qua CLI, dễ đọc rule).	Trung bình - Cao (Đòi hỏi hiểu biết cấu hình proxy, HTTP request).	Cao (Giao diện đồ sộ, cần kiến thức chuyên sâu về Web Security).	Thấp (Tương tác qua API/Prompt cực kỳ dễ dàng).
EShop fit	Rất cao (Chỉ điểm chính xác dòng code lỗi SQLi trong source EShop).	Cao (Rà quét trực tiếp trên các endpoint thực tế khi EShop đang chạy).	Rất cao (Công cụ số 1 để thâm nhập sâu vào logic nghiệp vụ mua hàng của EShop).	Cao (Phân tích chuyên sâu bối cảnh code lỗi của EShop và hướng dẫn sửa).
AI capability	Có hỗ trợ (Tích hợp Semgrep Assistant dùng AI để lọc lỗi và gợi ý bản vá).	Rất thấp (Chưa tích hợp AI native, chủ yếu quét truyền thống).	Đang phát triển (Có các extension như BurpGPT tích hợp LLM để phân tích HTTP).	Bản chất là nền tảng AI (Cung cấp API lỗi để xây dựng tính năng Triage và tự động hóa bảo mật).
Community size	Lớn (Cộng đồng DevSecOps phát triển mạnh, chia sẻ nhiều ruleset).	Rất lớn (Dự án flagship của OWASP, tài liệu phong phú, nhiều plugin).	Khổng lồ (Tiêu chuẩn thực tế - de facto của ngành bảo mật web).	Rất lớn (Cộng đồng sử dụng LLM cho DevSecOps đang phát triển mạnh mẽ).

3. LÝ DO CHỌN TỔ HỢP CÔNG CỤ

Đề xuất lựa chọn: Semgrep + Google Gemini API + OWASP ZAP

- **Giảm thiểu tỷ lệ False-Positive:** Semgrep cung cấp tốc độ quét tĩnh nhanh nhưng dễ sinh ra lỗi giả. AI (Gemini) sẽ đóng vai trò bộ lọc (Triage) thứ cấp, phân tích bối cảnh code của EShop để loại bỏ các cảnh báo không có thật.
- **Tăng tốc độ viết mã khai thác (PoC Exploit):** Thay vì kiểm thử viên tự xây dựng payload thủ công, AI tự động sinh ra các kịch bản khai thác. Sau đó, nhóm có thể đối chiếu và tấn công thử nghiệm bằng các công cụ tích hợp sẵn của OWASP ZAP để chứng minh lỗi đó là thật.
- **Tối ưu hóa quy trình vá lỗi:** Đề xuất mang lại một luồng kiểm thử khép kín và hoàn toàn miễn phí: Semgrep "phát hiện lỗi" -> Gemini "xác thực, giải thích và sinh payload/bản vá" -> ZAP "chứng minh thực tế" -> Developer áp dụng bản vá.

4. CÔNG BỐ SỬ DỤNG AI

Tuyên bố sử dụng AI: Nhóm 06 có sử dụng các mô hình AI tạo sinh (như ChatGPT / Gemini) như một trợ lý ảo để hỗ trợ tìm kiếm thông tin tổng quan, phân tích tính năng của Burp Suite/ZAP và tinh chỉnh văn phong kỹ thuật. Tuy nhiên, để đảm bảo tính chính xác và tránh hiện tượng "ảo tưởng thông tin" (AI hallucination), toàn bộ các tính năng, chi phí bản quyền và khả năng tích hợp của công cụ đều được nhóm tra cứu chéo và kiểm chứng trực tiếp với các nguồn tài liệu chính thức từ nhà phát hành (Semgrep Documentation, PortSwigger, OWASP Official Website) trước khi đưa vào báo cáo.